

The goal behind penetration testing is to assume a hacker-like mindset, so that real-life attacks are simulated using the tools that are most likely to be used by the attackers. Conducting these tests is a time-consuming activity, and needs to be performed by properly trained individuals to get the best results.

In order to cut down on the time element, many organisations aim for automating certain parts of the process. Though the penetration tests are still monitored by a skilled security analyst or a team of analysts, many steps of a penetration test can be easily automated. For example, manually running scans on each system will take up a significant amount of time, while these steps can be easily automated by using a vulnerability scanner to scan multiple systems at once. On similar lines, automated exploit tools can be used to perform an attack.

Automated penetration testing tools have multiple key benefits for an organisation. To start with, automated scans can be performed more quickly than manual scans, and hence, the speed of detecting new vulnerabilities also increases. Second, a security analyst will manually scan and test systems, one by one, which becomes a tedious process. Automated tools can cover a large number of systems for thousands of vulnerabilities. Third, with automated tools performing most of the basic parts of penetration testing, your internal team is not overloaded with monotonous work. It can instead focus its time on looking out for advanced attacks. Fourth, automated penetration testing tools can also play a major role in the compliance of certain standards or frameworks.

A number of commercial and open source automated penetration testing tools are available. In this article, we focus on the top five.

Metasploit

Metasploit was created by H.D. Moore in 2003 as a portable network tool using Perl. By 2007, the Metasploit Framework had been completely

rewritten in Ruby. On October 21, 2009, the Metasploit Project announced that it had been acquired by Rapid7, a security company that provides unified vulnerability management solutions.

Metasploit can be used to test the vulnerability of computer systems or to break into remote systems. Like many information security tools, Metasploit can be used for both legitimate and unauthorised activities. Since the acquisition of the Metasploit Framework, Rapid7 has added two open core proprietary editions called Metasploit Express and Metasploit Pro.

The basic steps for exploiting a system using the Metasploit Framework include:

1. Choosing and configuring an exploit for a specific target. Metasploit has over 300 exploits for various operating systems.
 2. Checking whether the intended target system is vulnerable to the chosen exploit.
 3. Choosing and configuring a payload. A payload is essentially code that will be executed once the targeted system gets compromised — for example, a remote shell.
 4. Executing the exploit.
- Metasploit contains a fully loaded pen testing toolkit comprising the following.
- **Exploits:** An exploit is a method by which the attacker takes advantage of a flaw within a system, service, application, etc. Exploits are always accompanied by payloads.
 - **Payload:** This is the piece of code that is run in the successfully exploited system.
 - **Auxiliary:** This provides additional functionality such as fuzzing, DoS attacks, scanning and recon, but it doesn't inject a payload like exploits.
 - **Encoders:** This obfuscates modules to avoid detection by a protection mechanism such as an antivirus or a firewall (e.g., backdoor creation).
 - **Nops:** This prevents the payload from crashing while using jump statements in its shellcode.

- **Post-exploitation:** A post-exploitation module enables you to gather more information or to gain further access to an exploited target system.
- **Shellcode:** This is a set of instructions that an exploit uses as the payload.

Main features of the Metasploit Framework:

- It is a penetration testing framework with more than 1800 exploits.
- It has 1000+ auxiliary modules, 300+ post-exploitation modules, 500+ payloads, as well as a lot of encoders and nops.
- Metasploit has a meterpreter module, which is an advanced, dynamically extensible payload.
- Command-line interface (mfsconsole), manual exploitation, manual credentials, brute forcing, and much more.

Features of Metasploit Pro:

- Web interface and Metasploit Pro console (to create and manage projects, scan and enumerate hosts, import and export data, configure and run modules, run automated exploits, view information about hosts, collect evidence from exploited systems, etc).
- Team collaboration capabilities (to share host data, view collected evidence, create host notes, divide pen testing into multiple parts, assign members a specific network segment to test, etc).
- It runs the following services: PostgreSQL (database), Ruby on Rails (Metasploit Pro Web Interface), Metasploit service, bootstraps Rails, the Metasploit Framework, and the Metasploit RPC server.
- Penetration testing workflow involves smaller and more manageable tasks and database exploits through a Web based user interface.
- Web app testing for OWASP Top 10 vulnerabilities, phishing awareness management and spear phishing, and much more.